

VentureMiner AI

Security Architecture

Document: 08-Engineering / 21_security

Version: v1.0

Date: 2026-07-20

Author: VentureMiner AI Documentation Team

Status: Approved

Project: VentureMiner AI — AI Venture Intelligence Platform

Table of Contents

Document 21 — Security Architecture

Table of Contents

1. Purpose & Scope
2. Threat model
3. Security principles
4. Identity & access
5. Network security
6. Application security
7. Data security
8. AI plane security
9. Tenant isolation
10. Secrets management
11. Vulnerability management
12. Incident response
13. Compliance
14. Audit & logging
15. Training & culture
16. Appendix
 - 16.1 Revision history
 - 16.2 Cross-references

Document 21 — Security Architecture

The contract for protecting customer data, the platform, and the AI plane. This document is the authoritative reference for all security decisions; deviations require a new revision.

Table of Contents

- 1. Purpose & Scope
- 2. Threat model
- 3. Security principles
- 4. Identity & access
- 5. Network security
- 6. Application security
- 7. Data security
- 8. AI plane security
- 9. Tenant isolation
- 10. Secrets management
- 11. Vulnerability management
- 12. Incident response
- 13. Compliance
- 14. Audit & logging
- 15. Training & culture
- 16. Appendix

1. Purpose & Scope

This document is the security contract. It applies to:

- All services in the OLTP plane.
- All services in the AI plane.
- All infrastructure (cloud, network, storage).
- All customer data at rest, in transit, and in use.

It does not cover physical security of cloud provider data centers (inherited from AWS).

2. Threat model

We use STRIDE to enumerate threats. The top categories:

Spoofing	Forged tokens, identity theft	OIDC, MFA, SSO, scoped tokens
Tampering	Source code injection, model poisoning	SAST, signed artifacts, RAG provenance

Spoofting	Forged tokens, identity theft	OIDC, MFA, SSO, scoped tokens
Repudiation	"I never did that"	Append-only audit log, signed events
Information disclosure	Cross-tenant leak, prompt leakage	RLS, PII redaction, per-tenant DEKs
Denial of service	API flood, expensive model calls	Rate limits, cost budgets, autoscaling
Elevation of privilege	RBAC bypass	RLS, server-side authz, regular review

Detailed model is reviewed every 90 days; a red-team is run annually.

3. Security principles

1. Defense in depth. No single control is the only thing standing between an attacker and data.
2. Least privilege. Every actor, service, and tool gets the minimum needed.
3. Secure by default. Off by default; opt-in to risk.
4. Verifiable. Every control is testable.
5. Auditable. Every state change is logged.

4. Identity & access

- AuthN: OIDC via Auth0; MFA via TOTP; SSO via SAML 2.0 / OIDC for Enterprise.
- AuthZ: RBAC at workspace level + per-resource ACLs where needed.
- Sessions: short-lived access tokens (15 min), rotating refresh tokens (30 days), idle timeout 8h.
- Token storage: httpOnly, secure, sameSite=Lax cookies for browser; secrets manager for server.
- Step-up: sensitive actions (export, delete, billing) require re-auth within 5 minutes.

5. Network security

- All public traffic terminates at Kong with TLS 1.3.
- Internal traffic is mTLS via service mesh.
- WAF in front of the API.
- DDoS protection at the edge.
- Outbound allow-listing for AI plane.

6. Application security

- SAST: Snyk in CI; daily scans.

- Secret scanning: git history + GitHub secret scanning.
- Threat modeling: per-PR for changes that affect security boundary.
- Code review: 2+ reviewers for any change to auth, crypto, RLS, or AI plane.

7. Data security

- Encryption at rest: AES-256 (KMS) for Postgres, OpenSearch, S3, Redis.
- Encryption in transit: TLS 1.3 for all network traffic.
- Per-tenant DEKs for sensitive tables (opportunity, validation, report).
- PII handling:
 - Identified at ingestion.
 - Pseudonymized in logs.
 - Redacted in LLM prompts.
- Encrypted at rest with tenant-specific DEK.
- Data residency: configurable per workspace; data never leaves the chosen region.

8. AI plane security

- Prompt injection defense: all retrieved content is treated as untrusted; instructions in retrieved content are not executed.
- Tool-call boundaries: agents cannot call tools outside the orchestrator's grant.
- PII redaction: at the AI plane boundary (AGT-SAFETY).
- Output filtering: verifier + safety filter.
- Model evaluation: weekly red-team of jailbreak and prompt injection.
- Source attribution: every claim is bound to a chunk and source URL.
- Cost ceilings: per-run and per-workspace budgets prevent runaway.

9. Tenant isolation

- DB: Row-level security on every tenant-scoped table.
- Search: shard key on workspace_id.
- Object store: key prefix per workspace; KMS key per workspace.
- RAG: per-tenant collection.
- Memory: scoped (Document 11).
- Application: every connection sets app.workspace_id per request.

10. Secrets management

- Rotation: model provider keys every 90 days; DB passwords every 30 days.
- Access: only the workload identity that needs the secret can read it.

11. Vulnerability management

- CVE monitoring: continuous.
- Patch SLAs:
 - Critical (CVSS ≥ 9.0): 24h
 - High (7.0–8.9): 7d
 - Medium (4.0–6.9): 30d
 - Low (< 4.0): 90d
- Pen test: annual + on major changes.
- Bug bounty: public program (post-launch).

12. Incident response

Detect	on-call	< 15 min
Triage	security on-call	< 30 min
Contain	platform + security	< 1 h
Eradicate	platform	< 24 h
Recover	platform + product	< 72 h
Postmortem	security	< 7 days

SEV levels in Document 18 §6.

13. Compliance

SOC 2 Type II	Target GA	Security + Compliance
ISO 27001	Target M18	Security + Compliance
GDPR	Launch	Legal + Security
CCPA	Launch	Legal + Security
HIPAA	Not in scope v1	—

14. Audit & logging

- Auth events: every sign-in, MFA challenge, role change.
- Data events: every read/write of customer data.
- Admin events: every admin action (config change, role grant, plugin install).

- Tamper evidence: append-only + chained hashes; daily anchor in S3 Object Lock.

15. Training & culture

- Onboarding: all engineers complete security training in week 1.
- Annual refresher: required for all employees.
- Tabletop exercises: quarterly.
- Security champions: one per team.

16. Appendix

16.1 Revision history

v0.5	2026-07-20	Doc Team	All sections drafted
v1.0	2026-07-20	Doc Team	First approved version

16.2 Cross-references

- TRD: Document 02 §10.
- Backend: Document 05 §11.
- MCP: Document 12.
- Operations: Document 28.

End of Document 21 — Security Architecture. Security is everyone's responsibility, and this is the contract for what that means here.